ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

PTC Kepware KEPServerEX / Kepware Server (OPC & industrial connectivity) · Component type: **Software Application (SAR) - OPC / industrial connectivity server** · Target SL = SL 3

Where to work	**KEPServerEX Configuration** (desktop config client); **Administrative Settings** = right-click the **system-tray icon › Settings** (User Manager; Security Policies; Configuration API Service Settings); **OPC UA Configuration** = right-click the tray icon › OPC UA Configuration (Server Endpoints; Instance Certificates). Runs as a Windows service on a hardened host.
Ports / paths	OPC UA endpoint default **opc.tcp://host:49320** (configurable). OPC DA = legacy **DCOM** (RPC 135 + dynamic). Configuration API **HTTPS TCP 57512** (HTTP 57412 - disable). IoT Gateway REST/MQTT agents (HTTPS / broker). App data = **C:\ProgramData\Kepware**; project files **.sopf** (or human-readable JSON). Config-API event log = **/config/v1/event_log**.
Notes	SAR - software application (OPC/industrial connectivity server), PTC Kepware. Confirm version (KEPServerEX V6 vs the newer "Kepware Server" rebrand) and installed drivers/plug-ins. Delivered secure choices matter: UA anonymous is off by default - keep it off; the OPC DA legacy interface and HTTP should be disabled.
How to read	Each row = one SL-3 requirement with native step-by-step (exact Settings/OPC UA/Config path) + command-level external-tool steps. Default read-only. Scans authorized; auth/injection tools ISOLATED lab only with written authorization.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	V6 / Kepware Server notes
SR/CR 1.1	Human user identification & auth	Confirm every access path authenticates. Open **Administrative Settings** (right-click the system-tray icon › Settings) › **User Manager**: the **Administrator** account (set at install) gates Settings; the **Server Users** group holds the runtime users. Confirm the **Default User** has a strong password (not blank) and that **UA anonymous login is disabled** (default). The Configuration client and Config API also require credentials. **Test:** connect an OPC UA client anonymously -> rejected; open Settings without the Administrator password -> denied. **Ext. tools:** UaExpert (connect Anonymous -> expect denied); `nmap -p 49320,57512 <host>` (endpoints in scope); Configuration client (login prompt).	All paths authenticate; Default User password set; UA anonymous off; no unauthenticated access.	V6 & Kepware Server.
SR/CR 1.2	Software process / device identification	Confirm the OPC UA server endpoint identity (server certificate) and that clients are identified: in **OPC UA Configuration › Server Endpoints** review the endpoint (adapter/port/policy); in **Instance Certificates** confirm the server certificate; client certs are trusted explicitly (Trusted Clients). **Ext. tools:** UaExpert (view server cert + endpoint policy); `nmap -p 49320 <host>`; Wireshark `opcua`.	Server endpoint + certificate identity confirmed; clients identified/trusted.	Kepware Server: Security Policies plug-in.
SR/CR 1.3	Account management	In **User Manager** review users/groups: keep **least privilege**, create purpose-specific **Server User groups** (e.g. one per OPC UA / REST / Config-API consumer), remove/rename defaults, no shared logins. The Windows Administrator account is managed per Windows best practice. **Ext. tools:** Settings › User Manager (group/user export/screenshot); Windows `net localgroup` for the OS accounts.	Purpose-specific groups; least privilege; no shared logins; defaults handled.	V6 & Kepware Server.
SR/CR 1.4	Identifier management	Confirm unique user identifiers in User Manager and a unique server/endpoint identity (host, OPC UA application URI, certificate); no reuse across instances. **Ext. tools:** User Manager (unique users); UaExpert (application URI); asset inventory.	Unique user and server identifiers; no reuse.	V6 & Kepware Server.
SR/CR 1.5 / 1.7	Authenticator management & strength	Per the Secure Deployment Guide, every KEPServerEX password (Administrator, Default User, group users, project file) should be **>=14 chars** with mixed case, numbers, and symbols. Confirm the policy is applied and defaults changed. **Ext. tools:** User Manager (password set for each account); policy evidence; store in the credential vault.	Strong (>=14 char) passwords on all accounts; no defaults; managed.	V6 & Kepware Server.

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	V6 / Kepware Server notes
SR/CR 1.6	Wireless access management	**N/A.** Software application with no wireless interface; wireless is managed at the host/network layer. **Ext. tools:** Confirm no device wireless; host WLAN governed by OS/network controls.	N/A - justification recorded (software application).	N/A
SR/CR 1.8 / 1.9	PKI certificates & key strength	For OPC UA, in **OPC UA Configuration › Instance Certificates** confirm the server certificate is **CA-signed** (Import Certificate), valid, strong-key - not the default self-signed; for the Config API and REST Server, import a CA-signed certificate in their service settings. Use current strong policies (Basic256Sha256+). **Ext. tools:** UaExpert (cert chain/policy); `openssl s_client -connect <host>:57512 | openssl x509 -noout -issuer -dates` (Config API TLS).	CA-signed certs on OPC UA / Config API / REST; strong keys; defaults replaced.	Kepware Server: newer policies default.
SR/CR 1.10	Authenticator feedback	Confirm the Configuration client, Settings, and OPC UA/Config-API logins mask password entry (no cleartext echo). **Ext. tools:** Visual verification at each interface.	Authenticators obscured during entry.	V6 & Kepware Server.
SR/CR 1.11	Unsuccessful login attempts	KEPServerEX has no native account lockout - record as a residual. Enforce lockout/throttling at the layers that authenticate (Windows/AD for OS, reverse-proxy/WAF in front of the Config API/REST) and monitor failed auth in the **Event Log** / SIEM. **Ext. tools:** Event Log review; reverse-proxy/WAF lockout; SIEM failed-auth; Hydra (ISOLATED, authorized) to prove the gap.	Lockout via OS/proxy; native gap recorded + compensating control.	Partial/Compensating.
SR/CR 1.12	System use notification	No native logon banner in the Configuration client/OPC UA; enforce the approved use notice at the Windows host (GPO logon banner) and on any web front-end/reverse proxy. **Ext. tools:** EWS `gpresult /h gp.html`; reverse-proxy banner config.	Use notice at host/proxy (compensating at app).	Compensating.
SR/CR 1.13	Access via untrusted networks	Confirm the OPC UA endpoint and Config API bind only to the trusted network adapter (Server Endpoints network-adapter selection) and are reachable only from the trusted zone; remote admin via VPN/jump host; front the Config API/REST with a reverse proxy + MFA. **Test:** from an untrusted VLAN, reach 49320/57512 -> must fail. **Ext. tools:** `nmap -Pn -p 49320,57512,135 <host>` from the untrusted side (expect filtered); firewall/ACL review.	Endpoints bound to trusted adapter; untrusted-network access denied; remote via VPN.	V6 & Kepware Server.

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	V6 / Kepware Server notes
SR/CR 2.1	Authorization enforcement	Confirm least privilege via **Security Policies**: open **Settings › Security Policies**, expand **Permissions assigned to Server Users** (and each group) and confirm read/write/browse are scoped per the principle of least privilege - e.g. an OPC UA read-only consumer cannot write tags or change config. **Test:** as a low-privilege group user, attempt a tag write / config change -> denied. **Ext. tools:** Settings › Security Policies (permission matrix screenshot); UaExpert as the low-priv user (write attempt -> denied).	Per-group least-privilege enforced; negative test confirms denial.	Kepware Server: Security Policies plug-in required.
SR/CR 2.2	Wireless use control	**N/A.** Software application, no wireless interface. **Ext. tools:** Confirm no wireless; host/network layer governs.	N/A - justification recorded.	N/A
SR/CR 2.3	Use control for portable/mobile devices	Control the engineering laptop and removable media on the host (OS device-control policy); only authorized project files (.sopf) and driver/plug-in installers loaded; restrict who can run the Configuration client. **Ext. tools:** Host removable-media GPO review; confirm project/installer provenance.	Portable/engineering media controlled at the host.	V6 & Kepware Server.
SR/CR 2.4 (+ SAR 2.4)	Mobile code	Control mobile/embedded code: restrict which drivers/plug-ins and any scripting (e.g. Advanced Tags / Local Historian expressions, IoT Gateway) are enabled to trusted, required ones; install only validated components (verify the digital signature at install). **Ext. tools:** Configuration (installed drivers/plug-ins list); verify installer digital signature (kepware.com/digitalsignature).	Only required, validated components/scripts enabled; no untrusted code.	SAR-specific.

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	V6 / Kepware Server notes
SR/CR 2.5	Session lock	Confirm the Configuration client / Settings require re-authentication and the host enforces a session/inactivity lock (OS screen lock); OPC UA sessions have bounded lifetimes. **Ext. tools:** Host inactivity-lock GPO; UaExpert (session timeout behavior).	Sessions lock/timeout on inactivity; re-auth required.	V6 & Kepware Server.
SR/CR 2.6	Remote session termination	Confirm OPC UA / Config-API sessions can be viewed and terminated and idle sessions close (OPC UA Diagnostics; Config API session management); reverse proxy can drop sessions. **Ext. tools:** OPC UA Diagnostics (active sessions); Wireshark (session teardown).	Remote sessions terminable on demand and on inactivity.	V6 & Kepware Server.
SR/CR 2.7	Concurrent session control	Confirm concurrent client sessions are bounded/monitored (OPC UA max sessions; licensing/tag-count limits) so a rogue client cannot exhaust the server. **Ext. tools:** OPC UA Diagnostics (session count); server Event Log.	Concurrent sessions limited/monitored.	V6 & Kepware Server.
SR/CR 2.8 / 2.12	Auditable events & non-repudiation	Confirm the **Event Log** captures security-relevant events (logins, config changes, connection events) with user attribution, and is forwarded to the SIEM. The Config API exposes the event log at **/config/v1/event_log**. Enable and route the Event Log persistence. **Test:** make a config change -> confirm an Event Log entry with user + action + time. **Ext. tools:** Configuration Event Log view; `curl -k -u user:pass https://<host>:57512/config/v1/event_log`; SIEM ingest.	Security events logged with attribution and forwarded.	V6 & Kepware Server.
SR/CR 2.9	Audit storage capacity	Confirm the Event Log persistence/size is configured and rotated (or offloaded to the SIEM) with alerting before overflow. **Ext. tools:** Event Log settings (size/rotation); SIEM retention.	Events retained/offloaded; alert before capacity.	V6 & Kepware Server.
SR/CR 2.10	Response to audit processing failures	Confirm the SIEM/collector alerts on Event Log forwarding failure so events are not silently lost. **Ext. tools:** SIEM source-silent alert; log-forwarder health.	Audit-failure alerting defined.	V6 & Kepware Server.
SR/CR 2.11	Timestamps	Confirm the host time source (NTP) is correct so Event Log and OPC UA timestamps are accurate and correlate with the SIEM/historian. **Ext. tools:** `w32tm /query /status`; Wireshark `ntp`.	Accurate, synchronized timestamps.	V6 & Kepware Server.

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	V6 / Kepware Server notes
SR/CR 3.1 / 4.1	Communication integrity & confidentiality	Enforce secured protocols and disable weak ones: **OPC UA** endpoints use Sign&Encrypt with a strong policy; **disable the OPC DA** legacy interface (Configuration › right-click Project › Project Properties › OPC DA › disable OPC 1.0/2.0/3.0); Config API and REST Server use **HTTPS only**; MQTT/REST client use TLS. **Test:** confirm the UA endpoint offers Sign&Encrypt and DA/HTTP are off. **Ext. tools:** Wireshark `opcua` (encrypted, not None); `nmap -p 135,49320,57412,57512 <host>` (DA/HTTP closed); UaExpert (policy = Basic256Sha256 SignAndEncrypt).	OPC UA Sign&Encrypt; OPC DA + HTTP disabled; TLS on API/REST/MQTT.	V6 & Kepware Server.
SAR 3.2	Protection from malicious code (component)	Confirm software integrity: validate the installer/executables via the Kepware **digital signature** (kepware.com/digitalsignature); host anti-malware with Kepware-aware exclusions; restrict install/upgrade to admins; only required drivers/plug-ins installed. **Ext. tools:** Windows `signtool verify /pa Server_Runtime.exe` (or file Properties › Digital Signatures); host AV; installed-component review.	Signed executables validated; install restricted; AV active.	SAR-specific.
SR/CR 3.3	Security functionality verification	After any change re-verify: UA anonymous off, Security Policies least privilege, OPC DA disabled, HTTP disabled, CA-signed certs, project-file password, against the Secure Deployment Guide baseline; compare the project/settings export. **Ext. tools:** Settings/OPC UA compare to baseline; `nmap -p 135,49320,57412,57512 <host>` (hardened state).	Security settings match the SDG hardening baseline after change.	V6 & Kepware Server.

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	V6 / Kepware Server notes
SR/CR 3.4	Software & information integrity	Protect the project file: **File › Save As › New Password** to encrypt the **.sopf** (avoid the human-readable JSON format for production); protect the **C:\ProgramData\Kepware** Application Data folder (grant read/write only to required users; remove inherited Users read); baseline + change-detect the project. **Ext. tools:** Configuration (Save As › New Password); Windows Security tab on ProgramData\Kepware; `certutil -hashfile project.sopf SHA256` for drift.	Project file encrypted; app-data ACLs least-privilege; integrity baselined.	V6 & Kepware Server.
SR/CR 3.5 (+ SAR 3.5)	Input validation	Confirm inputs are validated: the Config API and REST Server reject malformed/oversized requests and enforce **CORS whitelisting** (no asterisk); driver protocol parsing tolerates malformed frames. **ISOLATED:** fuzz the API/OPC UA on a test instance. **Ext. tools:** Config API/REST CORS setting review; Burp/ZAP against the API (ISOLATED); OPC UA fuzz (ISOLATED).	Inputs validated; CORS whitelisted; no injectable/oversized path.	SAR-specific.
SR/CR 3.6	Deterministic output	**N/A.** Software connectivity server; it does not directly drive a physical process output (deterministic/fail-safe output is a device-layer control). Confirm defined behavior of tag quality/comm-loss to clients. **Ext. tools:** Confirm tag quality = Bad on device comm loss (client sees status); no direct process output.	N/A - justification recorded (software application).	N/A
SR/CR 3.7	Error handling	Confirm errors/diagnostics are handled gracefully without leaking sensitive info; turn off verbose **Diagnostics** modes when not in use (per the SDG). **Ext. tools:** Configuration (Diagnostics off when unused); Event Log review.	Graceful error handling; diagnostics off when unused; no info leak.	V6 & Kepware Server.
SR/CR 3.8	Session integrity	Confirm OPC UA (Sign&Encrypt) and Config-API/REST (HTTPS) sessions are integrity-protected against replay/hijack; no unauthenticated/cleartext session path remains (DA/HTTP off). **Ext. tools:** Wireshark (encrypted sessions); confirm no cleartext DA/HTTP.	Sessions integrity-protected; no unauthenticated path.	V6 & Kepware Server.
SR/CR 3.9	Protection of audit information	Protect the Event Log and its store/forwarding; restrict who can read/clear it (User Manager permissions + host ACLs); secure the Config-API event-log endpoint (HTTPS + least-privilege user). **Ext. tools:** User Manager (event-log permissions); host ACL on log files; SIEM access review.	Audit records protected from unauthorized read/modify/delete.	V6 & Kepware Server.

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	V6 / Kepware Server notes
SR/CR 4.2	Information persistence	On decommission/repurpose, remove the encrypted project files, exported configs, certificates, and credentials; per the SDG remove backup/sample/test files; confirm no plaintext secrets persist. Encrypt the host disk (data at rest). **Ext. tools:** grep exports for secrets; confirm .sopf/certs/backups removed; BitLocker/disk-encryption status.	Secrets/projects/certs purged on decommission; disk encrypted.	V6 & Kepware Server.
SR/CR 4.3	Use of cryptography	Confirm modern crypto: OPC UA Basic256Sha256+ (Sign&Encrypt), Config-API/REST TLS 1.2/1.3, CA-signed certs; disable weak/deprecated policies (Basic128Rsa15/Basic256) and HTTP. **Ext. tools:** `testssl.sh https://<host>:57512`; UaExpert (policy list - weak ones removed).	Modern crypto in use; weak policies + HTTP disabled.	Kepware Server: deprecates weak UA policies.

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	V6 / Kepware Server notes
SR/CR 5.1 / 5.2	Network segmentation & zone boundary	Confirm the Kepware host sits in a controlled OT/DMZ zone behind a firewall; only required ports cross the boundary (OPC UA 49320, Config API 57512); OPC DA/DCOM not exposed across zones; front north-bound (Config API/REST/MQTT) with a proxy in the DMZ. **Ext. tools:** `nmap -p 135,49320,57412,57512,39320 <host>` per zone; firewall rule review; confirm DCOM not crossing zones.	Host in a segmented zone; only required flows cross the boundary.	V6 & Kepware Server.
SR/CR 5.3	General-purpose person-to-person comms restrictions	**N/A.** Connectivity server with no general-purpose person-to-person messaging. **Ext. tools:** Confirm no such services on the application.	N/A - justification recorded.	N/A

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	V6 / Kepware Server notes
SR/CR 5.4	Application partitioning	Partition by criticality: separate Server User groups/endpoints per consumer; where multiple trust levels exist, consider separate KEPServerEX instances/hosts rather than one flat server. **Ext. tools:** Review endpoint/group segregation; instance topology vs criticality.	Data/consumers partitioned by criticality (groups/endpoints/instances).	V6 & Kepware Server.

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	V6 / Kepware Server notes
SR/CR 6.1 / 6.2	Audit log accessibility & continuous monitoring	Confirm the Event Log is readable/exportable (Configuration Event Log; Config API **/config/v1/event_log**) by authorized users and forwarded to the SIEM; monitor server health/diagnostics and the host; passive OT IDS on the segment. **Ext. tools:** Config Event Log export; `curl -k -u user:pass https://<host>:57512/config/v1/event_log`; SIEM; passive OT IDS.	Events accessible/exportable and monitored in near-real-time.	V6 & Kepware Server.

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	V6 / Kepware Server notes
SR/CR 7.1	Denial-of-service protection	Confirm resilience: OPC UA session/connection limits, host resource limits, and boundary rate-limiting prevent a flood from denying connectivity; do not co-host with other apps (SDG). **Ext. tools:** ISOLATED: connection-storm/soak test; monitor host CPU/mem + OPC UA Diagnostics.	Resources bounded; connectivity continues under load.	V6 & Kepware Server.
SR/CR 7.2	Resource management	Confirm bounded resource use (max UA sessions, tag/connection limits, driver timeouts) so one client/driver cannot starve the runtime. **Ext. tools:** OPC UA / driver limits review; host resource monitor.	Resources bounded; no exhaustion-based loss of service.	V6 & Kepware Server.
SR/CR 7.3 / 7.4	Backup & recovery	Confirm the encrypted project (.sopf), User Manager/Security Policies config, and certificates are backed up (versioned, offline) and a restore is tested on a spare host for a known-good rebuild. **Ext. tools:** Backup repository review; restore + validate on a lab instance.	Backups current and recovery validated.	V6 & Kepware Server.
SR/CR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 7.6 / 7.7	Network & security settings + least functionality	Harden per the SDG: install only required drivers/plug-ins; disable OPC DA and HTTP; keep UA anonymous off; bind endpoints to the trusted adapter; turn off diagnostics when unused; remove non-production/sample files; keep the software upgraded. **Ext. tools:** Installed-feature review; `nmap -p 135,49320,57412,57512 <host>` (only required open); version vs latest.	Least functionality; unused interfaces/services disabled per the SDG.	V6 & Kepware Server.
SR/CR 7.8	Component inventory	Confirm the install (version/build, installed drivers, plug-ins, and OS) is inventoried so vulnerabilities track against PTC/Kepware security advisories and CISA ICS advisories. **Ext. tools:** Help › About / installed components; PTC/Kepware advisory feed; passive OT IDS inventory.	Accurate component/version inventory maintained; advisories tracked.	V6 & Kepware Server.

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
KEPServerEX Configuration (config client)	Native config & project review (all FRs)	Open the config client; right-click Project › Project Properties (disable OPC DA); File › Save As › New Password (encrypt .sopf); Event Log view. Export as the baseline.	Read/authorized copy.
Administrative Settings (system-tray › Settings)	User Manager & Security Policies (FR1, 2.1, 3.9)	Right-click the tray icon › Settings › User Manager (users/groups/passwords) and Security Policies (per-group permissions, least privilege).	Administrator credential required.

Tool / method	Verifies	How to use — steps / example	Constraints
OPC UA Configuration Manager	OPC UA endpoints & certs (1.2, 1.8, 3.1, 4.3)	Right-click the tray icon › OPC UA Configuration › Server Endpoints (adapter/port/policy - strongest) and Instance Certificates (Import CA-signed).	Non-intrusive.
Configuration API Service Settings	API hardening (1.13, 3.1, 6.x)	Settings › Configuration API Service Settings - disable HTTP (HTTPS only), Import CA-signed certificate, set CORS whitelist (no asterisk).	Non-intrusive.
UaExpert (OPC UA client)	UA auth, policy, session (1.1, 1.2, 2.x, 3.8)	Connect opc.tcp://host:49320; try Anonymous (expect denied), then a user; confirm policy = Basic256Sha256 SignAndEncrypt; view server cert; test least-privilege writes.	Read-only browse; no live writes.
nmap	Port/interface exposure & segmentation (1.13, 3.1, 5.x, 7.6)	`nmap -p 135,49320,57412,57512,39320 <host>` - confirm OPC DA/DCOM (135) and HTTP (57412) closed, only required open; scan per zone.	Read-only; authorized.
openssl / testssl.sh	TLS on Config API / REST (1.8, 4.3)	`testssl.sh https://<host>:57512`; `openssl s_client -connect <host>:57512` - confirm TLS1.2/1.3, strong ciphers, CA-signed cert.	Non-intrusive.
curl	Config API event log & auth (2.8, 6.x)	`curl -k -u user:pass https://<host>:57512/config/v1/event_log` - confirm auth required and the event log is retrievable; confirm HTTP (57412) refused.	Authorized read.
signtool	Executable signature validation (SAR 3.2)	`signtool verify /pa <file>.exe` or file Properties › Digital Signatures - confirm PTC/Kepware signature per kepware.com/digitalsignature.	Read-only.
Burp / OWASP ZAP / Hydra	API authz/injection & lockout gap (1.11, 3.5)	Proxy the Config API/REST to test authz, CORS, and input validation; Hydra to demonstrate the no-native-lockout gap.	ISOLATED/representative env; written authorization.

Controlled - Project Use · Independent Assurance Authority · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.